

Narrativa explicativa del marco GQM + PRAGMATIC aplicado a TLPT

1. De “métricas sueltas” a un sistema con brújula

Los indicadores TLPT por sí solos son como constelaciones sin nombres: brillan, pero cuesta orientarse. El enfoque GQM proporciona la brújula: cada métrica se ancla en un objetivo y en una pregunta explícita, conectando la estadística con la estrategia.[web:36]

Así, el % de funciones críticas cubiertas (M1) deja de ser un número caprichoso y pasa a ser la respuesta a una pregunta incómoda: “¿Dónde nos estamos dejando zonas de sombra?”.

El MTTD TLPT (M6) deja de ser “un dato de SOC” para convertirse en la medida de cuán ciegos estamos ante un adversario serio.

2. Cómo encaja GQM con DORA y TIBER-ES

DORA y los RTS sobre TLPT describen qué hay que hacer: quién entra en el sorteo del TLPT, cómo se organiza la prueba, qué debe incluir el informe y cómo se emite la attestation.[web:16]

TIBER-ES concreta el “cómo” operativo: fases TTI, Red Team, cierre, remediación y papel del TIBER Cyber Team.[web:38]

GQM sitúa por encima de todo eso una capa explícita de metas:

- Cobertura: que las funciones críticas, y sus proveedores TIC, pasen por el microondas del TLPT.
- Capacidad de reacción: que MTTD/MTTR no sean una confesión de derrota lenta.
- Mejora continua: que los hallazgos no se reencarnen ejercicio tras ejercicio.
- Gobernanza: que el ciclo trienal y los planes plurianuales sean algo más que un calendario en la pared.

3. El porqué del filtro PRAGMATIC

La tentación de cualquier programa de métricas es caer en el coleccionismo: cuantos más indicadores, mejor.

El criterio PRAGMATIC actúa como una aduana: solo pasan la frontera las métricas que sean predicativas, relevantes, accionables y, ya puestos, que no arruinen a nadie en el proceso.[web:36]

- Predictivo: evita enamorarse de métricas que solo describen el pasado.
- Relevante: impide que la métrica viva por sí misma, separada de DORA y de los objetivos nacionales.
- Accionable: si el valor sube o baja, debe implicar una decisión, no un suspiro.
- Genuino: cuanto más difícil de falsificar, mejor; el exceso de “self-assessment optimista” mata.
- Significativo: que un consejero pueda entenderlo en 10 segundos.
- Preciso: definiciones claras, sin espacio para manipular el denominador.
- Oportuno: si llega tarde, es opinión histórica, no indicador.
- Independiente: sin redundancias que acaben confundiendo más que ayudando.
- Rentable: el coste de calcularla no debe superar el beneficio de disponer de ella.

4. Usos recomendados del marco

- A nivel de país/sector: seleccionar un subconjunto de métricas M1–M16 como base para un “Cuadro de Resiliencia TLPT nacional”, con foco en cobertura, MTTD/MTTR y remediación.
- A nivel de entidad: usar el GQM para justificar por qué se mide lo que se mide y cómo se integran los resultados en el plan de inversiones de ciberseguridad y continuidad.
- A nivel de supervisores: explotar la comparabilidad que ofrece DORA/RTS para analizar tendencias de M6–M11 a escala agregada.[web:16][web:26]

5. Cómo contar la historia sin ahogar con números

Cada métrica debería poder usarse en una frase simple ante el consejo:

- “Hemos aumentado la cobertura de funciones críticas del 40 % al 75 % (M1), y eso reduce la probabilidad de sorpresas operativas en incidentes graves.”
- “Nuestro MTTD en TLPT ha pasado de 3 días a 6 horas (M6), aunque todavía llegamos tarde a ciertos vectores internos.”
- “La recurrencia de hallazgos (M11) sigue por encima del 30 %, señal de que remediar no siempre significa cerrar el ciclo.”

Si la frase no encaja en una línea clara, quizá la métrica esté pidiendo una revisión (o su jubilación digna).